

Identity and Access Management for Dataspaces using the European Business Wallet and eIDAS-based Credentials

Tobias Wich^[0000-0002-1180-1570], Detlef Hühnlein^[0000-0002-0316-7936], Tina
Hühnlein^[0009-0003-0634-6563], Mike Precht^[0009-0005-2679-3699], Michael
Rauh^[0009-0009-2880-1719], Neil Crossley^[0009-0002-1328-4092], Florian
Otto^[0009-0004-9939-072X], and Marina Artis^[0009-0001-7549-2746]

ecsec GmbH, Sudetenstr. 16, 96247 Michelau, Germany
`firstname.lastname@ecsec.de`
<https://ecsec.de>

Abstract. The European Commission recently announced the “European Business Wallet” (EUBW) as business-oriented companion to the human-centric and smartphone-based “European Digital Identity Wallet” (EUDIW) in order to boost the competitiveness of European enterprises. While a very important use case of the EUBW is the trustworthy data exchange in industrial Dataspaces using a suitable “Dataspace Protocol” (DSP), the currently available identity and access management approach based on the “Eclipse Decentralized Claims Protocol” (DCP) is unfortunately limited to self-issued identity tokens and decentralized identifiers lacking a clear trust framework and proprietary protocols for the issuance and presentation of credentials, which completely ignore existing standards in the web authorization domain, such as the “OAuth 2.0 Authorization Framework”, but instead resemble an existing patent, which is held by Microsoft Technology Licensing LLC.

This is extremely unfortunate for participants within European Dataspaces, because there is the well established and recently amended eIDAS Regulation (EU) No. 910/2014 in place and one may expect that most European enterprises will soon become “Wallet-Relying Parties” (WRP) in the sense of Art. 2 (1) of (EU) 2025/848, which are equipped with X.509-based “Wallet-Relying Party Access Certificates” (WRPAC) according to Art. 2 (12) of (EU) 2025/848. These certificates can not only be used for requesting credentials and claims from the EUDIW, but they can also be used for the automation of many other sensitive business processes using the EUBW and especially the trustworthy identity and access management in industrial Dataspaces across Europe and beyond. Against this background, we propose an alternative identity and access management architecture utilizing the widely accepted OAuth 2.0 framework and introduce the “Open Identity Protocol” (OIP), which can use the functionality of the EUBW together with standardized credentials including WRPACs, which seems to be much better aligned with the foreseeable European developments driven by the eIDAS Regulation and the forthcoming EUBW.

Keywords: Decentralized Identifiers (DIDs) · Eclipse Decentralized Claims Protocol (DCP) · European Business Wallet (EUBW) · European Digital Identity Wallet (EUDIW) · Open Authorization (OAuth) · Open Identity Protocol (OIP) · Verifiable Credential (VC)

1 Introduction

On the 29th of January 2025 the president of the European Commission, Ursula von der Leyen, presented the so called “Competitiveness Compass” [10,11], which aims at turning Europe into a place where future technologies, services, and clean products are invented, manufactured, and put on the market. It serves as roadmap and sets out the strategic course the European Commission will follow in the next five years. Among the announced “Flagship Actions enablers” for the year 2025 is the “European Business Wallet” (EUBW), which will build upon the amended eIDAS-Regulation (EU) No. 910/2014 and is envisioned to be “the cornerstone of doing business simply and digitally in the EU, providing a seamless environment for companies to interact with all public administrations.”

As outlined in Section 2.1 and discussed in [17] in more detail, the EUBW will typically¹ be a server-based system, which complements the human-centric and smartphone-based “European Digital Identity Wallet” (EUDIW) according to Article 3 (42) and 5a of (EU) No. 910/2014 in order to enable automated yet trustworthy electronic business and government processes across Europe. The technical characteristics of the EUDIW is outlined in a high-level manner within the “Architecture and Reference Framework”(ARF) [12], which is part of the common “Union Toolbox” recommended in (EU) 2021/946 and bindingly specified in detail within the growing set of implementing acts² and the technical standards referenced therein.

As explained in the recent paper “Towards the European Business Wallet” [17], there are many application scenarios and use cases for the forthcoming EUBW, whereas a particular important one is the trustworthy automated data exchange in industrial “Dataspaces”, for which the main concepts and characteristics are about to be standardized in ISO/IEC 20151 [21], using a suitable “Dataspace Protocol” (DSP), such as [19,28] for example, together with the corresponding identity, access and trust management mechanisms as discussed in the present paper.

For this purpose there is in particular the “Eclipse Decentralized Claims Protocol” (DCP) [2], which is unfortunately not based on widely accepted industry standards for web authorization and established trust frameworks, but rather

¹ In addition to the obvious server-based realization, one could imagine a large variety of different implementations, which also include tiny device wallets in form of embedded systems, which communicate with other smart devices using “Machine-to-Machine” (M2M) protocols or other EUBWs in order to realize a “Digital Product Passport” according to Art. 9 of (EU) 2024/1781 for example.

² See (EU) 2024/2977, (EU) 2024/2979, (EU) 2024/2980, (EU) 2024/2981, (EU) 2024/2982, (EU) 2025/846, (EU) 2025/847, (EU) 2025/848 and (EU) 2025/849.

utilizes self-issued identities, decentralized identifiers (DIDs) [40] together with potentially arbitrary DID-methods [42] and last but not least proprietary protocols for the issuance and presentation of credentials, which completely ignore existing and widely used and well analyzed standards in the web authorization domain, such as the “OAuth 2.0 Authorization Framework” specified in **RFC 6749** [15] and related standards, but instead seems to resemble the **patent** “Decentralized attribute-based access control” **US20230388287A1** [27], which has been granted on the 10th of December 2024 and which is currently held by **Microsoft Technology Licensing LLC**.

Therefore using DCP in industrial Dataspaces does not only impose a serious threat with respect to sovereignty, but potentially also creates additional security risks, because this set of protocols is not based on existing and well analyzed³ standards such as OAuth 2.0 and well defined trust frameworks, such as the one defined by the eIDAS-Regulation. Therefore it is very hard to reason about the overall security of such a system in a serious manner. Consequently, it is, unfortunately, currently rather unclear, whether one can finally put trust in an industrial Dataspace built on such uncertain grounds.

Against this background, the present paper proposes to utilize the widely accepted “OAuth 2.0 Authorization Framework” specified in **RFC 6749** [15] and related standards in order to end up with a set of protocols for the identity, access and trust management in Dataspaces, which we collectively call the “Open Identity Protocol” (OIP). This approach leverages the capabilities of the forthcoming EUBW in combination with standardized credentials, such as the X.509 [22] and **RFC 5280** [7] based “Wallet-Relying Party Access Certificates” (WR-PACs) and optionally additional electronic attestations, and aligns more closely with upcoming European developments driven by the amended eIDAS Regulation and the advent of the EUBW.

In addition to these obvious advantages for “Business-to-Business” (B2B) and “Business-to-Government” (B2G) processes, our approach also allows to easily integrate natural persons into the emerging Dataspaces in order to implement efficient “Business-to-Consumer” (B2C) and in a similar manner also “Government-to-Citizen” (G2C) processes. Note, that this feature does *not* require any additional effort, if one assumes that the EUBW is also acting as “Wallet-Relying Party” (WRP) according to Art. 2 (1) of (EU) 2025/848 in order to communicate with EUDIWs using the “OpenID for Verifiable Presentations” (OID4VP) protocol [41]. We assume that this feature may turn out to be crucial for Dataspaces in which natural person play a central role, such as in the recently enacted “European Health Data Space” (EHDS) according to (EU) 2025/327 for example.

The rest of the paper is structured as follows: Section 2 provides an overview of the system architecture in Section 1 and then recalls the most relevant existing related work. This includes a short summary of the existing versions of the DSP [19] and [28] in Section 2.2, for which the latter is envisioned to be submitted to

³ See RFC 6819 [29] and RFC 9700 [30] for OAuth 2.0 related security considerations and recommended practices.

ISO in the near future, the most important existing web authorization standards in Section 2.3, which may be used to realize an authentication and authorization layer for DSP, the most relevant aspects of DCP in Section 2.4 and the necessary background on the “OpenID for Verifiable Presentations” (OID4VP) protocol, which is used by WRPs to access the EUDIW which stimulated the creation of the present paper. Section 3 is the main part of the present paper in which we present our alternative “Open Identity Protocol” (OIP) based on the widely used “OAuth 2.0 Authorization Framework” according to **RFC 6749** [15] and eIDAS-based credentials, which may be expected to be available all over Europe soon. Section 4 discusses the advantages and disadvantages of the two approaches and we conclude the paper in Section 5 with a brief summary of the main results and an outlook with respect to possible further developments.

2 Background

2.1 Overview and System Architecture

As outlined in Figure 1 we concentrate on the typical setting of a Dataspace as described in [21,19,28] for example, in which there are at least two “Participants”, which are acting as “Provider” and “Consumer” of data and services, which are collectively called “Datasets”, and which are equipped with a “Participant Agent” or “Connector”⁴, which is a technical system that is registered within the Dataspace and acts on behalf of the Participant.

A practical implementation of such a Connector is the “Eclipse Dataspace Connector” (EDC), which has been designed and developed within the “Eclipse Dataspace Components” project and extended in related downstream projects, such as “Tractus-X” for example.

In line with the classical ISO OSI reference model defined in ISO/IEC 7498-1 [20] it is commonly assumed, that such a Connector has a “Control Plane”, which supports the DSP [19,28] as summarized in Section 2.2, and a “Data Plane”, which takes care about the data transport using some wire protocol, which is less relevant for the present paper.

Furthermore, we suggest to assume that there is an additional plane separate from the Control Plane, which takes care about the identity, access and trust management and is therefore called “Trust Plane” in Fig. 2 of [17] and also within the present paper.

In this layer lives the DCP [2], which will be briefly summarised in Section 2.4 and our alternative proposal OIP, which will be presented in Section 3 in more detail.

⁴ Note, that the term “Connector” is only used in DSP [19,28], but not in DCP [2], as there is a slightly different focus of the two not yet completely finalized specifications. We do *not* distinguish between these two terms here and rather treat them as synonymous.

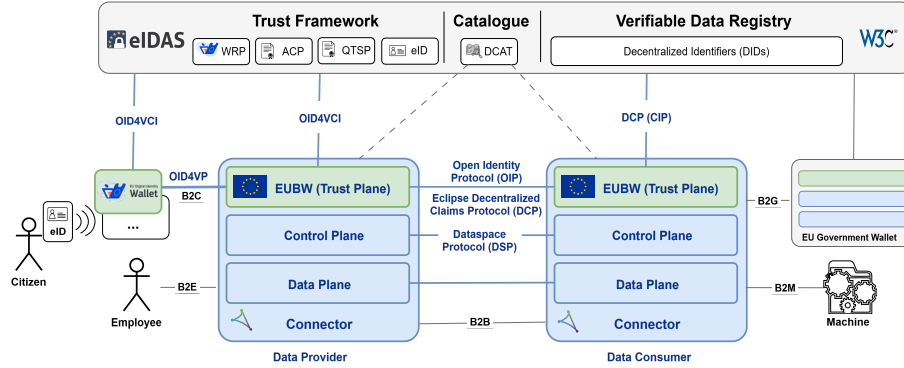


Fig. 1. System Architecture with EUBW in Dataspace

2.2 Dataspace Protocol

The DSP [19,28] lives on the Control Plane of the Connector and specifies a set of protocols and HTTPS⁵ bindings for

- the publication of metadata about “Resources” including Datasets available within a Dataspace using a “Catalog” based on the “Data Catalog Vocabulary” (DCAT) [1] for example, which may include or refer to “Policies” expressed within the “Open Digital Rights Language” (ODRL) [18] using the “Catalog Protocol” [28, Section 5 and 6],
- the negotiation of “Agreements” for the use of Datasets, which combine a concrete Policy associated with a specific Dataset that has been signed by both the Provider and Consumer using the “Contract Negotiation Protocol” [28, Section 7 and 8] and
- the transfer of data using the “Transfer Process Protocol” [28, Section 9 and 10], which features both a **push** and **pull** message exchange pattern with **finite** and **non-finite** data [28, Section 9.1.1.2].

While it is clear from a security perspective that there needs to be some sort of “Authentication”⁶ of the involved Connectors and the “Authorization”⁷ of the different web service requests from some client system within the sphere of the Consumer to some server system on the Provider side, it is important to understand, that DSP does not specify the details with respect to authentication and authorization, but leaves such details to the components within the “Trust

⁵ “Hypertext Transfer Protocol” (HTTP) according to RFC 9110 [14] over “Transport Layer Security” (TLS) according to RFC 8446 [37].

⁶ See [4] for an overview of protocols for authentication and key establishment.

⁷ See [33] for a systematic literature review for authorization and access control.

Plane”. Therefore the DSP specification [28] only contains a rather short Section 4.1 on authorization, which reads as follows:

*“All requests to HTTPS endpoints should use the **Authorization** header to include an authorization token. The semantics of such tokens are not part of these specifications. The **Authorization** HTTP header is optional if the Connector does not require authorization.”*

As there is no reference in DSP [28] to any of the existing HTTP specifications including the latest one in **RFC 9110** [14], it is unfortunately not entirely clear, what “the **Authorization** header” and the mentioned “authorization token” exactly means here, but one may guess that the **Authorization** header according to the HTTP specification could be meant here.

The corresponding definition in the latest HTTP specification in **RFC 9110** [14, Section 11.6.2] is as follows:

“The “Authorization” header field allows a user agent to authenticate itself with an origin server – usually, but not necessarily, after receiving a 401 (Unauthorized) response. Its value consists of credentials containing the authentication information of the user agent for the realm of the resource being requested.”

Note, that in this basic web model, there is a **HTTP Client**, called “user agent” in **RFC 9110** [14, Section 11.6.2], which is in a straightforward setting part of the Consumer sphere, and a **HTTP Server**, which is typically part of the Provider system. The HTTP Server is hosting some Resource and the HTTP Client wants to access this Resource and therefore needs to authenticate itself by providing some “credential” within the **Authorization** header mentioned above.

2.3 Authorization in the Web and the Dataspace Protocol

For the “credentials containing the authentication information” mentioned in **RFC 9110** [14, Section 11.6.2] there are numerous existing and widely used standards including

- the “*HTTP Digest Access Authentication*” according to **RFC 7616** [35], in which a **nonce** is offered by the server and the client responds with an unkeyed digest of the **username**, the **password**, the given **nonce** value, the HTTP method, and the requested URI,
- the “*Basic HTTP Authentication Scheme*” according to **RFC 7617** [36], in which the credentials are simply transmitted as Base64 encoded **user-id** / **password** pairs,
- the “*The OAuth 2.0 Authorization Framework*” with so called “Access Tokens” (AT) according to **RFC 6749** [15, Section 4], which are issued by an “Authorization Server”, which has previously authenticated the Client in the sense of **RFC 6749** and validated a so called “Authorization Grant”⁸,

⁸ Note, that **RFC 6749** [15, Section 1.3] specifies four different grant types (authorization code, implicit, resource owner password credentials, and

- the “*The OAuth 2.0 Authorization Framework*” with opaque “Bearer Tokens”⁹ according to **RFC 6750** [26],
- the “*Assertion Framework for OAuth 2.0 Client Authentication and Authorization Grants*” according to **RFC 7521** [6], which is an abstract framework, which needs to be considered together with its specific instantiations, such as
 - SAML according to [34] within the “*Security Assertion Markup Language (SAML) 2.0 Profile for OAuth 2.0 Client Authentication and Authorization Grants*” according to **RFC 7522** [5] and
 - JSON Web Tokens (JWT) according to **RFC 7519** [25] within the “*JSON Web Token (JWT) Profile for OAuth 2.0 Client Authentication and Authorization Grants*” according to **RFC 7523** [23], which plays a central role in our proposed OIP.

It is important to note, that despite the impressive number and great variety of existing standards for web authorization within the OAuth 2.0 family and the huge set of related Open Source tools and freely available enterprise solutions, such as Keycloak for example, the editor and key authors of DCP deliberately decided **not** to use any of these existing standards, but rather created something “new”, which seems to resemble their patent **US20230388287A1** [27]. Note, that the authors of DCP do not only seem to be negligent here, but even go one step further and “turn around” the commonly used, and well analyzed¹⁰, web authorization and related trust patterns, as in the “Presentation Flow” in [2, Section 5.1] there is an Access Token issued *within the sphere of the “Client”*, which is then shipped to the “Verifier” within the request to access the protected Resource in step (3), such that a corresponding verifiable presentation can later on be fetched by the Verifier in step (6).

2.4 Eclipse Decentralized Claims Protocol (DCP)

The “Eclipse Decentralized Claims Protocol” (DCP) [2] aims at complementing the DSP [19,28] by defining “a set of protocols for asserting participant identi-

client credentials) and in addition even provides an extension mechanism [15, Section 4.5 and 8], which allows to define additional grant types. Note, that the **client credentials** grant type is utilized in our proposed OIP in conjunction with **RFC 7523** [23].

⁹ Note, that there is the “OAuth 2.0 Demonstrating Proof of Possession (DPoP)” mechanism according to **RFC 9449** [13], which provides a cryptographic binding of the token to a key pair for enhancing security beyond bearer tokens and that there is a somewhat related internet draft for “OAuth 2.0 Attestation-Based Client Authentication” [32], which could provide even more security by providing a current attestation of the trustworthiness of the involved platform.

¹⁰ See **RFC 9700** [30] and the references therein.

ties, issuing verifiable credentials, and presenting verifiable credentials using a decentralized architecture for verification and trust.”

DCP is using “Verifiable Credentials” (VC) according to the “W3C Verifiable Credentials Data Model” (VCDM) (Version 1.1) [39] with “Self-Issued ID Tokens” and “Decentralized Identifiers” (DIDs) according to [40].

While the DID-Method [42], which is envisioned to be used in DCP is not precisely specified, the examples within the DCP specification [2] mention `did:web` [8].

DCP emphasizes to follow the classical role model with an “Issuer”, “Holder” and “Verifier” depicted both in [2, Figure 1] and [39, Figure 1] and the detailed internal structure of the Holder is shown in [2, Figure 1], which is included here for the convenience of the reader.

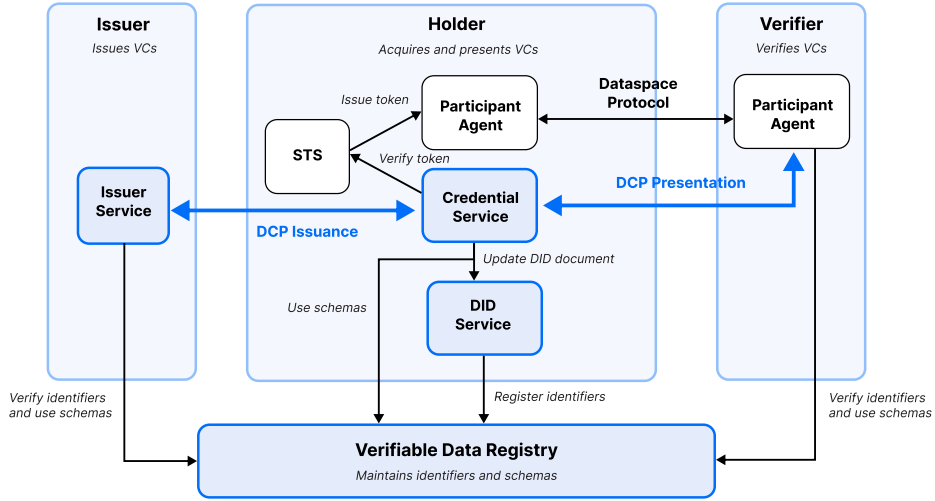


Fig. 2. Information Flow Architecture (from DCP [2, Figure 2])

The Holder contains a so called “Participant Agent”, which communicates with another Participant Agent within the “Verifier” via the DSP. These agents correspond to the Control Plane of the Connector in Figure 1 above. Furthermore, the Holder also contains the following identity-related agents, which essentially have the same purpose as the EUBW in the Trust Plane of the Connector in Figure 1 (see [2, Section 2.1.2]):

- *“Security Token Service (STS)”* – The STS creates self-issued authorization tokens that contain identity claims used by participant agents under the control of the same participant.
- *Credential Service (CS)* – The CS manages Verifiable Credentials. This includes read and write endpoints for Verifiable Presentations and Verifiable

Credentials.

- *DID Service* (DIDS) – The DIDS creates, signs¹¹ and publishes DID documents.

As explained in [2, Section 4.3] the Participants use Self-Issued ID Token to authenticate themselves and present self-attested claims to a Verifier. A Self-Issued ID Token is represented as a JWT according to **RFC 7519** [25], which is signed with a private key under the Participant’s control. The value of self-attested claims in industrial business processes seems to be worth to be discussed and clarified in the definition of a governing trust framework, which seems to be beyond the scope of the current DCP specification [2]. Furthermore, the details of the Self-Issued ID Tokens are unfortunately only sketched in [2, Section 4.3] and leave room for interpretation, which may in the end impose security and interoperability issues. The format of the Self-Issued ID Tokens seem to be a somewhat less sophisticated version of the JWT specified in **RFC7523** [23, Section 3.2], whereas the `iss` and `sub` claims are equal to the participants DID according to [40] and likely `did:web` [8].

As stated in [2, 4.3.1] “a Self-Issued ID Token MAY contain an access token as a `token` claim that can be used by the Verifier to obtain Verifiable Presentations from the participant’s Credential Service.” The capital letter “MAY” indicates, that including the `token` claim is optional, but it remains unclear, whether this is correct, because in this case the presence of the STS in DCP would also be optional, which does not seem to make sense in any realistic production environment.

Finally, it seems to be worth to mention, that the “Self-Issued ID Tokens” in DCP are handled in a completely different fashion as the equally named tokens mentioned in the “Self-Issued OpenID Provider” (SIOP) specification [43], as the later are issued by an OAuth based OpenID Provider, whereas the tokens in DCP are issued by the STS in an “implementation-specific” way (see [2, Section 4.3.2]), which may be based on the OAuth 2.0 “*Client Credential Grant*” according to **RFC 6749** [15, Section 4.4] (see [2, Section 4.3.2.1.]).

The following figure takes a closer look at the presentation flow of the DCP, where the Holder, which is referred to as Client here, interacts with a Verifier to present a Verifiable Credential.

The presentation flow begins with the issuance of a Self-Issued ID Token including an Access Token in step (1) and (2), which is sent to the Verifier in step (3). This token contains the DID of the Holder/Client as well as the DID of the Verifier. The Verifier resolves the Holder’s DID and retrieves the Credential Service endpoint address from the DID in the steps (4) and (5). Using the Self-Issued ID Token, the Verifier then requests a “Verifiable Presentation” (VP) from the Holder’s Credential Service in step (6). Upon validating the ID Token, the Holder responds with the requested VP in step (7), which contains the requested

¹¹ It seems to be questionable, whether this is indeed correct, because signing DID documents to create a VC seems to be among the tasks of an Issuer in a VC-based system according to [39].

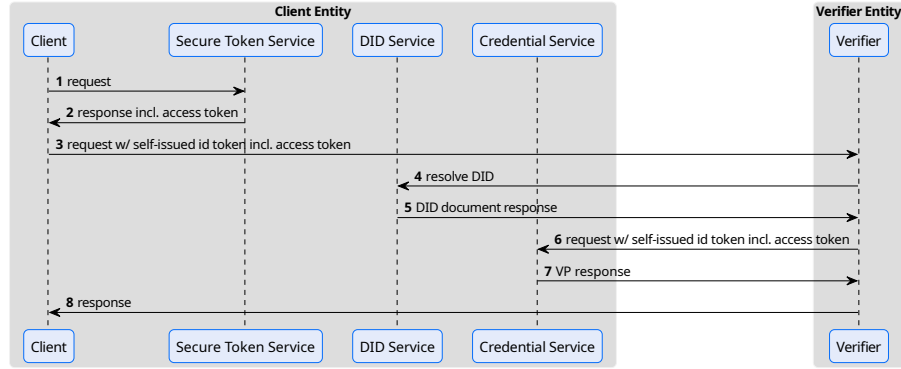


Fig. 3. Presentation Flow (from DCP [2, Figure 4])

claims. The Verifier can validate the received VP and check it against suitable policies. If the validation passes, the requested resources are returned to the Holder by the Verifier in step (8). More details with respect to the presentation flow can be found in the DCP protocol specification [2, Section 5.1].

The “*Credential Issuance Protocol*” specified in [2, Section 6] as part of DCP also uses the STS to issue Self-Issued ID Token, which are then sent to the *Issuer Service*. The Self-Issued ID Token contains the DID of the Holder, which is verified and resolved by the Issuer Service. Based on this verification, the request is either approved or rejected. If approved, the Issuer Service generates the Verifiable Credential (VC) and delivers it to the Holder’s Credential Service. Further information about this process can be found in the specification of the DCP protocol [2, Section 6.1].

We do not go into more details here, as the functionality provided by the Credential Issuance Protocol is already available in a more mature fashion within the widely used “*OpenID for Verifiable Credential Issuance*” (OID4VCI) protocol [31].

2.5 Access Certificates for Wallet-Relying Parties

Art. 5a of the amended eIDAS Regulation (EU) No. 910/2014 has triggered various activities in all European Member States to design, implement, certify and roll-out the “European Digital Identity Wallet” (EUDIW) as technically outlined in the “Architecture and Reference Framework”(ARF) [12] until the end of 2026. As the EUDIW will in particular enable the user to use strong authentication and identification on a high level of assurance, sign by means of qualified electronic signatures by default and free of charge, while providing interesting security and privacy features, such as authenticating the accessing “Wallet-Relying Parties” (WRP)¹² using their X.509-based “Wallet-Relying Party Access Certifi-

¹² See Art. 2 (1) of (EU) 2025/848.

cates” (WRPAC)¹³, it seems to be reasonable to assume that such certificates will be broadly available in Europe after 2027.

These certificates are not only based on X.509 [22] and **RFC 5280** [7], but further profiled in ETSI TS 319 411-8 [9] to foster security and interoperability. The WRPAC in particular allows to create advanced electronic signatures or seals on the **Authorization Request** within OID4VP [41, Section 5] in form of a “JSON Web Signature” (JWS)¹⁴ according to **RFC 7515** [24], as required by the “OpenID4VC High Assurance Interoperability Profile” (HAIP) [44], which stipulates that the EUDIW shall support the “Client Identifier Prefix” `x509_san_dns` according to [41, Section 5.9.3].

The central idea of the present paper is to utilize the WRPAC not only for accessing the EUDIW in a B2C process, but also for similar authorization requests in a B2B Dataspace within the “Trust Plane” of an EUBW.

3 Open Identity Protocol (OIP)

The DSP [19,28] uses the standard HTTP **Authorization** header [14, Section 11.6.2] for authentication against a Connector endpoint. It does not specify further requirements with respect to the authentication and authorization scheme, which allows to combine the DSP [19,28] with a wide variety of authentication and authorization mechanisms. OAuth 2.0 based on **RFC 6749** [15] and the related family of standards (see Section 2.3) is nowadays the de facto standard for authentication and authorization in web-based environment using Bearer tokens to authenticate requests and authorize web endpoints, making it an ideal fit for the DSP [19,28].

Therefore our proposed “Open Identity Protocol” (OIP) is consciously designed to utilize the well established and widely accepted standards from the OAuth 2.0 family, whenever possible, to realize the required authentication and authorization functionality to be plugged into DSP and ideally allow to use existing stock components, which are sometimes even available as enterprise-grade Open Source. This makes our OIP fit very well into the modern web and allows the solution to utilize existing and freely available “Authorization Server” (AS) and “Client” components, such as Keycloak for example.

As Dataspace environments are inherently decentralized and federated, typically each participant and Connector maintains its own AS in order to control access to its endpoints in the Control plane and its provided resources, such as its Datasets, which are typically registered in the local Catalog of the Connector and shared with the central Catalog of the Dataspace. The AS authenticates and authorizes the foreign party on behalf of the accessing Connector and issues an “Access Token” (AT), which is then used to access the Connector API on the Control Plane. The accessed Connector therefore realizes the role of a “Resource Server” (RS), while the accessing Connector is the Client in the sense

¹³ See Art. 2 (12) of (EU) 2025/848.

¹⁴ Note, that a JWS according to **RFC 7515** [24] is by definition also a JWT according to **RFC 7519** [25].

of **RFC 6749** (see [15, Section 1.1]). The accessed Connector can then validate the provided AT and extract further information about the accessing subject with “Token Introspection” according to **RFC 7662** [38], or alternatively evaluate the standardized JWT-based Access Tokens according to **RFC 9068** [3], which may even simplify the overall message flow and integration.

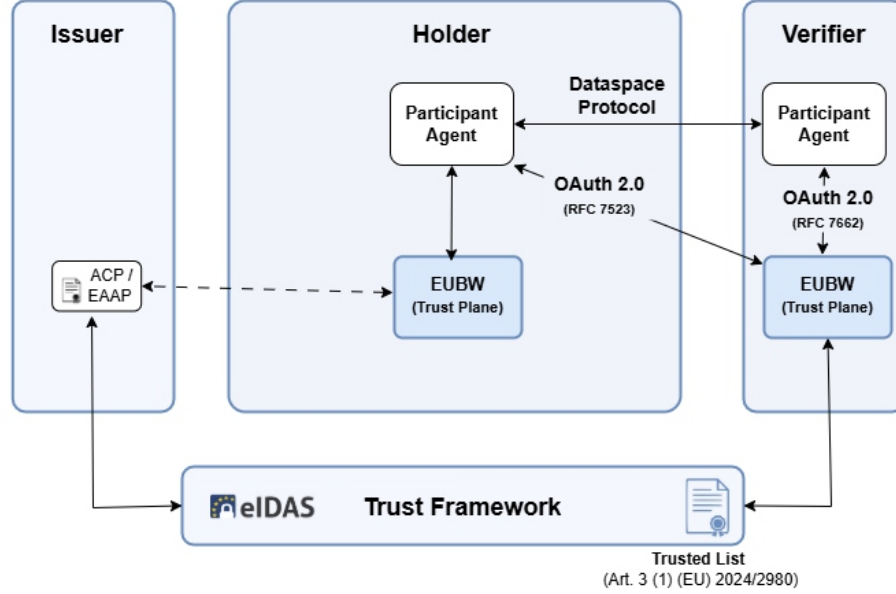


Fig. 4. Overview of the Open Identity Protocol using EUBW

Note, that the identity within the `sub` claim of the JWT within the client authentication and possibly further claims about the authenticated client may be evaluated by an external “Policy Engine”, as explicitly depicted within the overview diagram in the previous version of the DSP [19].

3.1 Basic JWT-based Token Request using the EUBW

OAuth is in general very unspecific with regard to the actual authentication means. This allows to plug in any method, which fulfils the applicable policy and security requirements of the environment. The EUBW may be expected to also act as WRP and consequently has an X.509-based WRPAC, which can be used to identify the legal entity owning the wallet. It can therefore be easily used to register and authenticate a participant in a Dataspace. Although registration of an OAuth Client in the context of Dataspaces is not discussed further in this paper, it should be noted, that the WRPAC can be used to identify the

Participant there, too. It is further assumed that the registration of the OAuth Client is established beforehand.

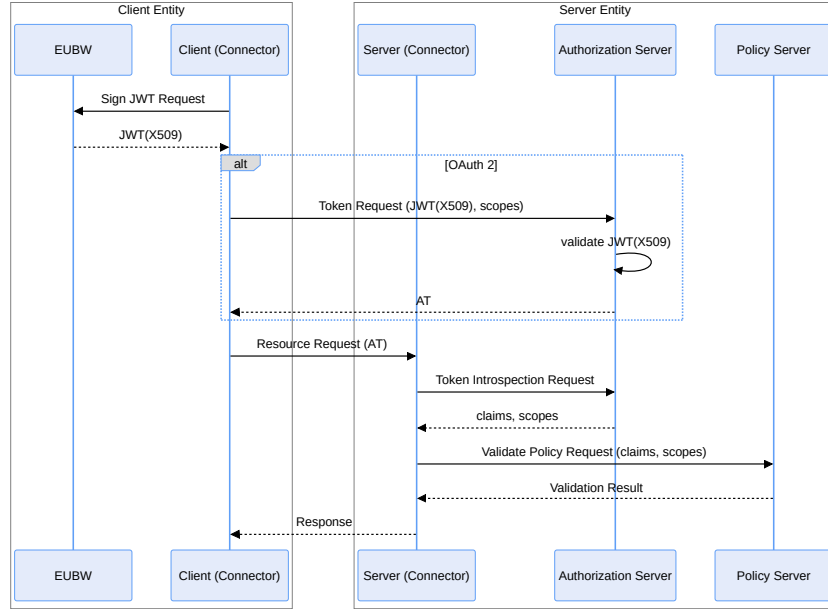


Fig. 5. Basic JWT-based Token Request using the EUBW

The basic JWT-based Token Request, as shown in Figure 5, starts by creating a JWT signed by the EUBW using the WRPAC. This JWT is signed by the key registered for this Client in the AS of the Data Provider. The Client can then directly use the JWT to authenticate itself while invoking directly the token endpoint using a JWT-based authentication according to **RFC 7523** [23] using a simple “Extension Grant”¹⁵ according to Section 4.5 of **RFC6749** [15].

The AS of the Data Provider then validates the JWT with the used X.509-based WRPAC and determines whether the requestor is allowed to receive an AT for the Control Plane of the Connector. Optionally provided scope values may further specify the operations the Client intends to use with the AT. Once the request is validated, the Client receives the AT for further use within the Control Plane of the Connector within the DSP.

Note, that the previous version of the DSP from 2024 [19] contained an explicit step in which the eligibility of the request is determined by performing

¹⁵ When performing machine-to-machine based Client authentication, a preceding Authorization Request makes no sense, and is indeed not necessary as explained in the description of the closely related “Client Credential Grant” (see Section 4.4 of **RFC 6749** [15]).

a policy evaluation. In the OAuth 2.0 variant discussed here, the right place to perform this policy evaluation seems to be after the resource request has been issued and further information has been retrieved for the authentication and authorization of the requestor. This may include claims, scope values, and other metadata, which are available either in the AT itself, as specified in **RFC 9068** [3], or by performing an additional token introspection call according to **RFC 7662** [38] against the AS.

3.2 Using additional Electronic Attestations

Although using the WRPAC of the EUBW provides a very simple mechanism, that can be realized with widely available standard components and services, since only finalized and widely accepted standards from the OAuth 2.0 family are utilized in our OIP, the information available to the AS during authentication may be quite limited depending on the detailed content of the WRPAC, which is currently specified ETSI TS 119 411-8 [9].

In order to overcome this potential limitation and harness the full power of the EUBW and the trust framework of the eIDAS-Regulation, it would be desirable to have the option to include additional self-asserted claims and further electronic attestations issued by some trusted third party in the JWT, which is used for requesting the AT at the Token Endpoint of the AS. Fortunately, this possibility for including additional claims and attestations has already been considered in [23, Section 3, Nr. 8], which clearly states that “The JWT MAY contain other claims.”

Furthermore, it is clear that corresponding credentials and electronic attestations from trusted third parties can simply be obtained using the widely accepted OID4VCI protocol [31], and the initial step in Figure 5 may use a simplified¹⁶ profile of the standardized OID4VP protocol [41] between the EUBW and the Connector, which in this case acts as relying party for the EUBW here.

Finally, it seems to be worth to be noted here, that – depending on the specific policy and security requirements within the Dataspace – one may instead or additionally utilize the “OAuth 2.0 Attestation-Based Client Authentication” [32] in order to utilize attestation mechanisms in order to ensure and attest the trustworthiness of the involved platforms, which may in particularly be useful in so called “Compute-to-Data” scenarios as outlined in [45].

4 Discussion

The DCP [2] uses Verifiable Credentials for authentication and authorization within the DSP. Issuing these credentials can be seen as the registration step necessary for the participation in a Dataspace, or to apply for access to a specific Connector. These credentials are then used as claims data sources for the access

¹⁶ Note, that the Connector and the EUBW are typically operated in the same environment, there is no need to utilize Access Certificates and the security enhanced HAIP [44] here.

decision after a resource request has been issued. Unfortunately, this construction makes it necessary to deviate from mainstream architectural web authorization patterns and invent a non-standard protocol flow, where VPs can be retrieved with an AT issued within the wallet of the Holder. It also deviates from the well-established methodology that an Access Token for a Resource Server is issued by the entity owning the Resource, such as a Dataset for example. Instead, the AT is intended for the issuer of the resource request and can be used to retrieve the asserted information about the requestor.

On the other hand, our strictly OAuth 2.0 based OIP proposed in this paper, does not invent a new method for registration, authentication and authorization, but simply utilizes well-established standards from the OAuth 2.0 family. This has the important benefit, that the required components and services for the base variant can be realized with unmodified standard components from the OAuth 2.0 domain.

Our approach also allows to include additional self-attested claims or electronic attestations issued by a trusted third party in the JWT-based authentication request to meet additional policy and security requirements.

Finally, a nice and noteworthy side-effect of our OAuth-based proposal is, that at the core it only deals with Access Tokens. It is therefore very easy to remove all parts regarding the internal details of the JWT and policy based claims validation, thus massively simplifying test and development setups.

As already mentioned, the registration for the participation in a specific Dataspace, or for the individual access to a specific Connector in a Dataspace, is a mandatory part of the DCP approach, but in our OAuth-based proposal this is not necessarily the case, because the registration to participate within the eIDAS ecosystem has already happened within the registration process at the “national register of wallet-relying parties” according to Art. 2 (10) of (EU) 2025/848 as a prerequisite to obtain the WRPAC, which is later on used for identity and access management within the Dataspace or for other use cases of the EUBW.

If an explicit registration within a specific Dataspace or with an individual business partner is necessary, this can easily be achieved using standard means and protocols. For example, the EUBW uses a WRPAC, and possibly further electronic attestations can be obtained using standard protocols such as OID4VCI [31]. Finally, it is needless to say that the existing and legally endorsed trust framework, according to the amended eIDAS-Regulation (EU) No. 910/2014 can easily be combined with other contractual agreements and identity management mechanisms, such as those detailed by decentralized identifiers [40] or OpenID Federation [16].

5 Conclusion and Outlook

In the present paper we have presented a standard-based alternative to DCP for the identity and access management in industrial Dataspaces based on the DSP [19,28], which we call the “Open Identity Protocol” (OIP). It utilizes the

X.509-based WRPAC, which are assumed to be broadly available in 2027 and beyond. As discussed in the present paper, our OIP has several advantages compared to the previously existing DCP – especially in European Dataspaces in which one may expect, that there will soon be a large population of European enterprises, which also act as WRP and hence already have a governmentally trusted and endorsed WRPAC at hand. Our OIP has also important advantages within international Dataspaces, as this protocol is not touched by the patent **US20230388287A1** [27], which seems to closely resemble DCP.

We intend to present our novel approach to interested stakeholders within the European and international Dataspace communities. Further steps may follow after the initial discussions with relevant communities and stakeholders around the Eclipse, Gaia-X, Catena-X, Tractus-X, Manufacturing-X, and sphin-X for example.

We kindly acknowledge that the present paper has greatly benefited from the fruitful exchange of thoughts with numerous Dataspace and identity management experts including Christian Bormann, Werner Folkendt and Torsten Lodderstedt for example.

Finally, we gratefully acknowledge, that the present work has been supported by the German Federal Ministry of Economics and Energy within the partially funded research projects TEAM-X and moveID and last but not least by the Free State of Bavaria within the GRANIT project.

References

1. Albertoni, R., Browning, D., Cox, S.J.D., Beltran, A.G., Perego, A., Winstanley, P.: Data Catalog Vocabulary (DCAT) - Version 3. W3C Recommendation (8 2024), <https://www.w3.org/TR/vocab-dcat-3/>
2. Bertagnolli, A., Koen, P., Kollenstart, M., Latzelsperger, P., Marino, J., Pampus, J., Rajani, R., Risa, E., Ruland, M., Scholtes, B., Schulte, N., Spiekermann, M., Steinbuss, S., Weiß, A., Yildiz, H.: Eclipse Decentralized Claims Protocol v1.0-RC3 (March 2025), <https://eclipse-dataspace-dcp.github.io/decentralized-claims-protocol/v1.0-RC3/>
3. Bertocci, V.: JSON Web Token (JWT) Profile for OAuth 2.0 Access Tokens. IETF RFC 9068, <https://www.rfc-editor.org/rfc/rfc9068>
4. Boyd, C., Mathuria, A., Stebila, D.: Protocols for Authentication and Key Establishment. Springer (2020)
5. Campbell, B., Mortimore, C., Jones, M.: Security Assertion Markup Language (SAML) 2.0 Profile for OAuth 2.0 Client Authentication and Authorization Grants. IETF RFC 7522, <https://www.rfc-editor.org/rfc/rfc7522.html>
6. Campbell, B., Mortimore, C., Jones, M., Goland, Y.: Assertion Framework for OAuth 2.0 Client Authentication and Authorization Grants. IETF RFC 7521, <https://www.rfc-editor.org/rfc/rfc7521.html>
7. Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., Polk, W.: Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. IETF RFC 5280 (05 2008), <https://www.rfc-editor.org/rfc/rfc5280>
8. did:web Method Specification. Unofficial Draft 31 July 2024, <https://w3c-ccg.github.io/did-method-web/>

9. ETSI TS 119 411-8: Electronic Signatures and Infrastructures (ESI); Trust Service Providers issuing certificates; Part 8: Common Access Certificate Policy for EUDI Wallet Relying Parties. Draft (2025), https://portal.etsi.org/webapp/WorkProgram/Report_WorkItem.asp?WKI_ID=74431
10. European Commission presents its compass to boost Europe's competitiveness in the next five years (2025), https://ec.europa.eu/commission/presscorner/detail/en/ac_25_385
11. European Commission: Competitiveness Compass for the EU. Communication from the Commission to the European Parliament, the European Council, the Council, the European Economic and Social Committee and the Committee of the Regions (2025), https://commission.europa.eu/document/download/10017eb1-4722-4333-add2-e0ed18105a34_en
12. European Digital Identity Wallet Consortium: Architecture and Reference Framework (ARF) (2025), <https://eu-digital-identity-wallet.github.io/eudi-doc-architecture-and-reference-framework/2.1.0/architecture-and-reference-framework-main/>
13. Fett, D., Campbell, B., Bradley, J., Lodderstedt, T., Jones, M., Waite, D.: OAuth 2.0 Demonstrating Proof of Possession (DPoP). IETF RFC 9449, <https://datatracker.ietf.org/doc/html/rfc9449>
14. Fielding, R., Nottingham, M., Reschke, J.: HTTP Semantics. IETF RFC 9110, <https://www.rfc-editor.org/rfc/rfc9110>
15. Hardt, D.: The OAuth 2.0 Authorization Framework. IETF RFC 6749, <https://www.rfc-editor.org/rfc/rfc6749>
16. Hedberg, R., Jones, M., Solberg, A., Bradley, J., Marco, G.D., Dzhuvinov, V.: OpenID Federation 1.0 - draft 42 (03 2025), https://openid.net/specs/openid-federation-1_0.html
17. Hühnlein, T., Hühnlein, D., Stöcker, C., Schwalm, S.: Towards the European Business Wallet. Proceedings of Open Identity Summit 2025 (2025), <https://dl.gi.de/items/c1d7ff4a-374a-4c11-a81e-64c5cc607e04>
18. Iannella, R., Villata, S.: ODRL Information Model 2.2. W3C Recommendation (2018), <https://www.w3.org/TR/odrl-model/>
19. International Data Spaces Association: Dataspace Protocol 2024-1 (2024), <https://docs.internationaldataspaces.org/ids-knowledgebase/dataspace-protocol>
20. ISO/IEC: Information technology — Open Systems Interconnection — Basic Reference Model: The Basic Model. ISO/IEC 7498-1 (1994)
21. ISO/IEC: Information technology — Cloud computing and distributed platforms — Dataspace concepts and characteristics. ISO/IEC DIS 20151 (2025)
22. ITU-T: Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks. Recommendation X.509 (10 2019), <https://www.itu.int/rec/T-REC-X.509-201910-I/en>
23. Jones, M.: JSON Web Token (JWT) Profile for OAuth 2.0 Client Authentication and Authorization Grants. IETF RFC 7523, <https://www.rfc-editor.org/rfc/rfc7523.html>
24. Jones, M., Bradley, J., Sakimura, N.: JSON Web Signature (JWS). IETF RFC 7515, <https://www.rfc-editor.org/rfc/rfc7515>
25. Jones, M., Bradley, J., Sakimura, N.: JSON Web Token (JWT). IETF RFC 7519, <https://www.rfc-editor.org/rfc/rfc7519>
26. Jones, M., Hardt, D.: The OAuth 2.0 Authorization Framework: Bearer Token Usage. IETF RFC 6750, <https://www.rfc-editor.org/rfc/rfc6750>

27. Koen, P., Jahromi, B.G., Dingle, P., von der Wiele, S.M., Marino, J., Latzelsberger, P.: Decentralized attribute-based access control. US patent, US20230388287A1 (December 2024), <https://patents.google.com/patent/US20230388287A1/en>
28. Koen, P., Kollenstart, M., Marino, J., Pampus, J., Turkmayali, A., Steinbuss, S.: Dataspace Protocol 2025-1-RC1 (February 2025), <https://eclipse-dataspace-protocol-base.github.io/DataspaceProtocol/2025-1-RC1/>
29. Lodderstedt, T., E., McGloin, M., Hunt, P.: OAuth 2.0 Threat Model and Security Considerations. IETF RFC 6819, <https://www.rfc-editor.org/rfc/rfc6819>
30. Lodderstedt, T., Bradley, J., Labunets, A., Fett, D.: Best current practice for oauth 2.0 security. IETF RFC 9700, <https://datatracker.ietf.org/doc/html/rfc9700>
31. Lodderstedt, T., Yasuda, K., Looker, T.: OpenID for Verifiable Credential Issuance (12 2024), https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0.html
32. Looker, T., Bastian, P., Bormann, C.: OAuth 2.0 Attestation-Based Client Authentication. IETF Draft draft-ietf-oauth-attestation-based-client-auth-05 (3 2025), <https://www.ietf.org/archive/id/draft-ietf-oauth-attestation-based-client-auth-05.html>
33. Mohamed, A.Y.S., Auer, D., Hofer, D., Küng, J.: A systematic literature review for authorization and access control: definitions, strategies and models. International journal of web information systems 18.2/3, 156-180 (2022)
34. OASIS: Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0. OASIS Standard (03 2005), <https://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf>
35. R. Shekh-Yusef, E., Ahrens, D., Bremer, S.: HTTP Digest Access Authentication. IETF RFC 7616, <https://www.rfc-editor.org/rfc/rfc7616>
36. Reschke, J.: The 'Basic' HTTP Authentication Scheme. IETF RFC 7617, <https://www.rfc-editor.org/rfc/rfc7617>
37. Rescorla, E.: The Transport Layer Security (TLS) Protocol Version 1.3. IETF RFC 8446, <https://www.rfc-editor.org/rfc/rfc8446>
38. Richer, J.: OAuth 2.0 Token Introspection. IETF RFC 7662, <https://www.rfc-editor.org/rfc/rfc7662>
39. Sporny, M., Longley, D., Chadwick, D.: Verifiable Credentials Data Model v1.1 (3 2022), <https://www.w3.org/TR/vc-data-model/>
40. Sporny, M., Longley, D., Sabadello, M., Reed, D., Steel, O., Allen, C.: Decentralized Identifiers (DIDs) v1.0 (7 2022), <https://www.w3.org/TR/did-core/>
41. Terbu, O., Lodderstedt, T., Yasuda, K., Looker, T.: OpenID for Verifiable Presentations (6 2025), https://openid.net/specs/openid-4-verifiable-presentations-1_0.html
42. W3C: DID Methods. W3C Group Note (1 2025), <https://www.w3.org/TR/did-extensions-methods/>
43. Yasuda, K., Jones, M., Lodderstedt, T.: Self-Issued OpenID Provider v2 - draft 13 (2023), https://openid.net/specs/openid-connect-self-issued-v2-1_0.html
44. Yasuda, K., Lodderstedt, T.: OpenID4VC High Assurance Interoperability Profile - draft 03 (2 2025), https://openid.net/specs/openid4vc-high-assurance-interoperability-profile-1_0-03.html
45. You, J., Wu, J., Jin, X.X., Chowdhury, M.: Ship compute or ship data? why not both? In: Proceedings of the 18th USENIX Symposium on Networked Systems Design and Implementation. April 12–14 (2021)